

CYB-046 : Configuration et supervision d'un SIEM

Introduction Générale du Cours

Au cœur de tout Security Operations Center opérationnel se trouve une infrastructure technologique indispensable : le SIEM. Security Information and Event Management — derrière cet acronyme se cache la plateforme qui centralise, corrèle et valorise l'ensemble des événements de sécurité d'un système d'information. Sans SIEM, les analystes naviguent dans un océan de logs dispersés sur des dizaines de systèmes hétérogènes, incapables de relier entre eux les événements qui, mis bout à bout, révèlent une attaque en cours.

L'accessibilité des solutions SIEM open source a transformé ce domaine autrefois réservé aux grandes entreprises dotées de budgets conséquents. Des plateformes comme Wazuh ou l'ELK Stack offrent aujourd'hui des capacités comparables aux solutions commerciales leaders — Splunk, IBM QRadar, Microsoft Sentinel — à un coût d'acquisition nul, au prix d'un investissement en compétences techniques pour leur déploiement et leur maintien en condition opérationnelle. Ce rapport coût / efficacité les rend particulièrement pertinentes pour les PME, les ETI et les organisations publiques souhaitant construire une capacité de détection sans budget de grands groupes.

Ce cours explore en profondeur la mise en place et la supervision d'un SIEM open source, en couvrant l'ensemble du cycle : choix de la solution adaptée au contexte, architecture et déploiement, configuration des sources de collecte, création et optimisation des règles de détection, construction des tableaux de bord de supervision, et mesure de la performance. Les deux solutions de référence — Wazuh pour sa complétude en tant que SIEM tout-en-un, et l'ELK Stack pour sa puissance et sa flexibilité — sont traitées en parallèle pour permettre une comparaison éclairée et un choix adapté au contexte de chaque organisation.

Objectifs Pédagogiques du Module

À l'issue de ce cours, l'apprenant doit être capable de :

1. Maîtrise Conceptuelle et Architecturale

- Comprendre le rôle et les fonctions d'un SIEM dans une architecture de cyberdéfense.
- Distinguer les solutions SIEM open source (Wazuh, ELK Stack, Graylog) selon leurs architectures, fonctionnalités et cas d'usage.
- Concevoir une architecture SIEM adaptée à la taille et aux contraintes d'une organisation.

2. Compétences Techniques de Déploiement

- Installer et configurer Wazuh (manager, indexer, dashboard) sur un serveur Linux.
- Déployer et configurer les agents Wazuh sur des endpoints Linux et Windows.

- Mettre en place un pipeline ELK Stack (Filebeat, Logstash, Elasticsearch, Kibana) fonctionnel.
- Sécuriser les communications entre composants avec le chiffrement TLS.

3. Expertise en Détection et Corrélation

- Comprendre la logique de décodage et de règles dans Wazuh (décodeurs XML, règles, niveaux de criticité).
- Créer des règles de détection personnalisées couvrant des scénarios d'attaque spécifiques.
- Développer des règles de détection mappées sur le framework MITRE ATT&CK.
- Configurer des pipelines Logstash avec des patterns grok pour parser des formats de logs complexes.

4. Supervision et Amélioration Continue

- Construire des tableaux de bord de supervision adaptés aux besoins d'un analyste SOC.
- Définir et suivre les KPIs de performance d'une infrastructure SIEM.
- Mettre en œuvre une politique de rétention et de gestion du cycle de vie des index.

Chapitre 1 : Panorama des SIEM Open Source

1. Fonctions Fondamentales d'un SIEM

Un SIEM remplit cinq fonctions essentielles qui structurent son architecture et guident son déploiement. La collecte est la première : agréger les événements de sécurité issus de l'ensemble des sources du SI — serveurs, postes, équipements réseau, applications, cloud — en un point centralisé. La normalisation transforme ces événements hétérogènes (Syslog, CEF, JSON, Windows Event Log, format propriétaire) en un format unifié permettant leur traitement cohérent. L'enrichissement ajoute un contexte à chaque événement : géolocalisation des adresses IP, correspondance avec des listes de menaces (threat intelligence), informations sur la criticité de l'actif source issues de la CMDB.

La corrélation est le cœur intellectuel du SIEM : elle consiste à mettre en relation des événements issus de sources différentes pour détecter des patterns d'attaque qui ne seraient pas visibles en examinant chaque source isolément. Un seul échec d'authentification est un événement banal ; dix échecs en deux minutes depuis la même IP externe suivis d'une authentification réussie constituent un pattern de brute force réussi qui justifie une alerte immédiate. Enfin, l'alerte et le reporting transforment les détections en actions concrètes pour les analystes et fournissent à la direction les indicateurs de performance nécessaires au pilotage de la sécurité.

2. Comparatif des Solutions SIEM Open Source

Le marché open source propose plusieurs solutions SIEM matures, aux architectures et positionnements différents. Le tableau suivant présente une comparaison structurée des principales solutions pour guider le choix selon le contexte :

Critère	Wazuh	ELK Stack	Graylog	OpenSearch Security
Licence	Open source (GPL)	Open source / Elastic	Open source (SSPL)	Open source (Apache 2)
Architecture	Agent + Manager + Indexer	Beats + Logstash + ES + Kibana	Sidecar + Graylog + MongoDB + OS	Collecteur + OpenSearch + Dashboard
Facilité de déploiement	Élevée (tout-en-un)	Moyenne (composants séparés)	Élevée (interface intuitive)	Moyenne
Détection intégrée	Oui (règles HIDS, FIM, SCA)	Partielle (via règles Elastic)	Non native (via pipelines)	Partielle
Support Windows	Oui (agent natif)	Oui (Winlogbeat)	Oui (NXLog / Winlogbeat)	Oui (agent)
MITRE ATT&CK mapping	Oui (natif)	Oui (via Elastic Security)	Non natif	Partiel
Cas d'usage idéal	PME / ETI, SOC débutant	SOC mature, gros volumes	PME, centralisation logs	Migration depuis ES payant

Ce comparatif met en évidence deux positionnements complémentaires. Wazuh est particulièrement adapté aux organisations souhaitant un SIEM complet et opérationnel rapidement, avec des capacités de détection intégrées (HIDS, FIM, SCA) qui ne nécessitent pas de développement de règles de zéro. L'ELK Stack est le choix privilégié des équipes techniques matures souhaitant une plateforme totalement flexible et scalable, capables d'investir dans la configuration et le développement des pipelines et des règles de détection.

3. Critères de Choix d'un SIEM Open Source

Au-delà des fonctionnalités, plusieurs critères pratiques doivent guider le choix de la solution SIEM. La volumétrie est le premier paramètre dimensionnant : un SI de 50 équipements génère des volumes très différents d'un SI de 5 000 postes. Wazuh et Graylog conviennent bien aux volumes modérés, tandis que l'ELK Stack offre une meilleure scalabilité horizontale pour les très grands volumes grâce au clustering Elasticsearch natif.

La maturité de l'équipe technique est un critère tout aussi important. Un SIEM est un outil à haute valeur ajoutée mais aussi à haute exigence de maintenance : les agents doivent être déployés et mis à jour sur l'ensemble du parc, les règles doivent être calibrées pour réduire les faux positifs, les index doivent être gérés pour maîtriser l'espace disque. Une équipe débutante bénéficiera davantage de Wazuh dont l'interface intégrée simplifie ces opérations, tandis qu'une équipe expérimentée exploitera pleinement la puissance de l'ELK Stack. Les contraintes budgétaires sur l'infrastructure (RAM, CPU, stockage) et les exigences de

rétenion réglementaire (12 mois pour NIS2, 5 ans pour DORA dans le secteur financier) déterminent enfin le dimensionnement de la solution.

Chapitre 2 : Architecture et Déploiement de Wazuh

1. Architecture de Wazuh

Wazuh est une plateforme SIEM open source complète, issue du fork d'OSSEC (Open Source HIDS Security), enrichie de nombreuses fonctionnalités modernes et dotée d'une interface web intuitive. Son architecture repose sur quatre composants principaux qui interagissent selon une topologie en étoile, les agents transmettant leurs données vers un manager central qui les traite et les transmet à l'indexer pour stockage et visualisation :

Composant	Rôle	Technologies sous-jacentes
Wazuh Agent	Collecte des événements sur chaque endpoint supervisé et envoi au manager	Daemon léger (C/C++), multiplateforme : Linux, Windows, macOS, Solaris
Wazuh Manager	Réception, décodage, analyse et corrélation des événements ; génération des alertes	Démon ossec-analysisd, règles XML, moteur de décodage
Wazuh Indexer	Stockage et indexation des alertes et des événements pour la recherche et la visualisation	OpenSearch (fork d'Elasticsearch 7.10)
Wazuh Dashboard	Interface web de supervision, visualisation des alertes, gestion des agents et des règles	OpenSearch Dashboards (fork de Kibana)
Filebeat	Transport des alertes du manager vers l'indexer, avec chiffrement TLS	Elastic Beats (Go)

Cette architecture est conçue pour être déployée sur un ou plusieurs serveurs dédiés, séparés des systèmes supervisés. Pour une infrastructure de taille modeste (jusqu'à 500 agents environ), une installation tout-en-un sur un unique serveur Linux est possible. Pour des infrastructures plus grandes, les composants peuvent être distribués sur plusieurs serveurs pour répartir la charge, avec un cluster d'indexeurs pour la haute disponibilité.

2. Prérequis et Installation de Wazuh

L'installation de Wazuh s'effectue sur un serveur Linux (Ubuntu 22.04 LTS ou RHEL 8/9 sont les distributions de référence officiellement supportées). Les prérequis matériels minimaux pour une installation tout-en-un supportant jusqu'à 100 agents sont : 8 Go de RAM (16 Go recommandé), 4 cœurs CPU, et 100 Go de stockage SSD pour les index. Ces chiffres doivent être ajustés à la hausse en fonction du volume d'événements générés par les agents.

Wazuh propose un script d'installation assistée qui automatise le déploiement des quatre composants en quelques minutes. La commande `curl -sO https://packages.wazuh.com/4.x/wazuh-install.sh && bash wazuh-install.sh -a` télécharge et exécute ce script, qui installe et configure automatiquement le manager, l'indexer (OpenSearch), le dashboard (OpenSearch Dashboards) et Filebeat. À l'issue de l'installation, le dashboard est accessible via HTTPS sur le port 443, avec les identifiants générés automatiquement affichés dans la sortie du script. Cette approche tout-en-un est idéale pour une mise en route rapide ; des installations composant par composant sont documentées pour les architectures distribuées.

3. Déploiement des Agents Wazuh

Un agent Wazuh doit être déployé sur chaque système à superviser. Son déploiement s'effectue depuis l'interface dashboard (Menu Agents > Deploy new agent) ou en ligne de commande. L'interface génère automatiquement la commande d'installation adaptée à l'OS cible (Linux, Windows, macOS), incluant l'adresse du manager et la clé d'enregistrement. Sur un endpoint Windows, la commande PowerShell générée télécharge le MSI officiel, l'installe silencieusement et enregistre l'agent auprès du manager en une seule opération.

Sur les systèmes Linux, l'agent s'installe via le gestionnaire de paquets de la distribution. Une fois installé, le fichier `/var/ossec/etc/ossec.conf` est le fichier de configuration principal de l'agent. Il définit les journaux à surveiller (section `localfile`), les répertoires à surveiller pour le File Integrity Monitoring (section `syscheck`), la fréquence des vérifications de configuration (section `sca`) et les éventuelles commandes de réponse active à autoriser. Pour les grandes infrastructures, le déploiement des agents peut être automatisé via des outils d'orchestration comme Ansible ou des GPO pour les parcs Windows.

4. Sécurisation des Communications

Par défaut, Wazuh chiffre les communications entre agents et manager avec un protocole propriétaire. Pour les communications entre le manager et l'indexer (via Filebeat), un certificat TLS est configuré automatiquement lors de l'installation. Il est recommandé de remplacer ces certificats auto-signés par des certificats émis par la PKI interne de l'organisation ou par une autorité de certification reconnue, afin de garantir l'authenticité des composants et d'éviter les attaques de type man-in-the-middle sur le flux de logs.

L'accès au dashboard Wazuh doit être restreint au réseau de management (VLAN d'administration) et protégé par une authentification forte. Wazuh supporte nativement l'intégration avec des annuaires LDAP et Active Directory pour l'authentification des utilisateurs du dashboard, ainsi que le contrôle d'accès basé sur les rôles (RBAC) permettant de distinguer les droits des analystes N1 (lecture des alertes), N2 (accès aux agents et aux règles) et administrateurs (configuration complète).

Chapitre 3 : Règles de Détection dans Wazuh

1. Architecture des Règles Wazuh

Le moteur de détection de Wazuh repose sur deux composants distincts qui travaillent en séquence : les décodeurs (decoders) et les règles (rules). Les décodeurs sont des parseurs qui transforment les messages de log bruts en événements structurés en extrayant les champs pertinents : adresse IP source, nom d'utilisateur, action réalisée, code de retour. Les règles s'appliquent sur ces événements structurés pour identifier les comportements suspects et générer des alertes.

Les décodeurs sont définis en XML dans le répertoire `/var/ossec/ruleset/decoders/` (décodeurs officiels) et `/var/ossec/etc/decoders/` (décodeurs personnalisés). Chaque décodeur définit un pattern de correspondance (prematch ou program_name) et des expressions régulières pour extraire les champs. Par exemple, le décodeur SSH extrait depuis les messages `auth.log` les champs `srcip` (adresse IP source), `srcuser` (nom d'utilisateur) et `srcport` (port source) à partir du message `Failed password for root from 192.168.1.100 port 54321`.

2. Structure et Niveaux des Règles

Les règles Wazuh sont organisées selon une hiérarchie de niveaux de criticité de 0 à 15. Le niveau détermine l'action déclenchée et la visibilité de l'alerte dans le dashboard. Le tableau suivant présente cette hiérarchie et les types d'événements associés :

Niveau	Criticité	Exemples de règles	Action typique
0 – 3	Informationnel	Démarrage de service, connexion réussie standard	Journalisation sans alerte
4 – 7	Faible à modéré	Échec d'authentification unique, modification de fichier non critique	Alerte faible, revue périodique
8 – 11	Élevé	Brute force détecté, rootcheck positif, exécution de commande suspecte	Alerte immédiate analyste N1
12 – 15	Critique	Intrusion confirmée, compromission de compte root, malware détecté	Escalade N2, réponse active possible

Une règle Wazuh en XML se compose de plusieurs éléments : un identifiant unique (id), le niveau de criticité (level), la référence à la règle parente si la règle est une spécialisation (if_sid), le groupe fonctionnel (group, utilisé pour le mapping ATT&CK), la description

(description), les conditions de correspondance (match, regex, srcip, dstip, user, etc.) et éventuellement les informations de conformité (mitre, pci_dss, gdpr).

3. Création de Règles Personnalisées

Les règles personnalisées se placent dans `/var/ossec/etc/rules/` et sont automatiquement chargées par le manager au démarrage. Elles utilisent des identifiants compris entre 100 000 et 999 999 (les identifiants inférieurs à 100 000 sont réservés aux règles officielles Wazuh). Une règle personnalisée efficace s'appuie sur les règles existantes : plutôt que de parser entièrement un nouveau format, on crée une règle enfant (if_sid) qui se déclenche uniquement lorsqu'une règle parente a déjà qualifié l'événement, permettant d'ajouter des conditions supplémentaires.

Un exemple de règle personnalisée détectant l'utilisation de PowerShell avec des arguments encodés — technique classique d'obfuscation utilisée par les attaquants (T1059.001) — se structure ainsi : la règle référence le groupe windows_security via if_group, cherche la chaîne EncodedCommand dans le champ de commande via un élément match, est assignée au niveau 12 (critique), et inclut la référence MITRE T1059.001 dans son groupe. Après rechargement du manager (ossec-control restart), cette règle génère immédiatement une alerte critique pour toute exécution PowerShell avec des arguments encodés sur l'ensemble des agents Windows supervisés.

4. Modules de Détection Intégrés

Au-delà des règles classiques basées sur les logs, Wazuh intègre plusieurs modules de détection spécialisés qui enrichissent considérablement ses capacités. Le module File Integrity Monitoring (FIM) surveille en temps réel les modifications apportées aux fichiers et répertoires critiques définis dans la configuration de l'agent. Toute création, modification, suppression ou changement de permissions sur un fichier surveillé (par exemple `/etc/passwd`, `/etc/sudoers`, `/usr/bin/` sous Linux ou `C:\Windows\System32\` sous Windows) génère une alerte Wazuh avec le détail de la modification, l'utilisateur ayant effectué l'action et l'horodatage précis.

Le module Security Configuration Assessment (SCA) évalue périodiquement la conformité de la configuration des systèmes supervisés par rapport à des benchmarks de sécurité reconnus : CIS Benchmarks pour Windows et Linux, NIST SP 800-53, PCI-DSS. Il produit un score de conformité par système et liste les contrôles non conformes avec leur description et les actions correctives recommandées. Ce module transforme Wazuh en outil d'audit de configuration automatisé, complémentaire des scanners de vulnérabilités traditionnels.

Chapitre 4 : Architecture et Configuration de l'ELK Stack

1. Vue d'Ensemble du Pipeline ELK

L'ELK Stack (Elasticsearch, Logstash, Kibana) est l'architecture de gestion de logs la plus déployée dans le monde, utilisée aussi bien pour les logs applicatifs que pour la cybersécurité. Sa modularité — chaque composant est indépendant et remplaçable — en fait une plateforme extrêmement flexible, capable de s'adapter à des architectures allant du serveur unique au cluster distribué de centaines de nœuds. Le tableau suivant présente le pipeline complet, de la collecte à la visualisation :

Étape	Composant	Fonction	Configuration clé
1. Collecte	Beats (Filebeat, Winlogbeat, Auditbeat)	Lecture des sources de logs sur les endpoints et envoi vers Logstash ou ES	Fichier beats.yml : chemins de logs, output, TLS
2. Traitement	Logstash	Parsing, transformation, enrichissement et filtrage des événements	Pipeline input / filter (grok, mutate, geoip) / output
3. Indexation	Elasticsearch	Stockage distribué, indexation full-text et recherche des événements	Index templates, ILM policies, mapping
4. Visualisation	Kibana	Tableaux de bord, exploration des données, alerting et gestion des règles de détection	Kibana.yml, espaces, RBAC, alertes KQL/EQL

2. Configuration de Filebeat pour la Collecte

Filebeat est l'agent de collecte léger déployé sur chaque système source. Il lit les fichiers de logs spécifiés dans sa configuration, suit leur progression (bookmarking) pour ne pas re-lire les événements déjà transmis, et les envoie vers Logstash ou directement vers Elasticsearch. Sa configuration principale se trouve dans `/etc/filebeat/filebeat.yml`.

La configuration de Filebeat pour la collecte des logs système Linux définit une entrée de type log pointant vers `/var/log/syslog` et `/var/log/auth.log`, avec le champ `fields.log_type` défini à `linux_syslog` pour permettre le routage dans Logstash. Pour les logs Windows, Winlogbeat remplace Filebeat et collecte nativement les canaux Event Log (Security, System, Application, PowerShell/Operational). La sortie Logstash est configurée avec l'adresse du serveur, le port (5044 par défaut) et les paramètres TLS. Les modules Filebeat pré-configurés (nginx, apache, auditd, iptables) activent automatiquement les configurations de collecte et les dashboards Kibana associés, accélérant considérablement la mise en route pour les sources les plus courantes.

3. Pipeline Logstash — Parsing et Enrichissement

Logstash est le moteur de transformation du pipeline ELK. Un pipeline Logstash est défini dans un fichier de configuration composé de trois blocs obligatoires. Le bloc input définit les sources d'entrée : Beats sur le port 5044 pour recevoir les événements des agents Filebeat et Winlogbeat, Syslog UDP sur le port 5140 pour les équipements réseau, ou TCP avec TLS pour les sources nécessitant une transmission chiffrée fiable.

Le bloc filter est le cœur du pipeline. Il applique séquentiellement des plugins de transformation sur chaque événement. Le plugin grok est le plus utilisé : il parse les messages de logs non structurés en extrayant des champs nommés via des patterns. Le pattern prédéfini COMBINEDAPACHELOG parse en une seule ligne l'intégralité d'un log Apache (IP, horodatage, méthode, URL, code de retour, taille, référent, user-agent). Le plugin mutate ajoute, modifie ou supprime des champs. Le plugin geoip enrichit les adresses IP avec leur géolocalisation (pays, ville, coordonnées GPS pour les visualisations cartographiques). Le plugin translate effectue des correspondances clé-valeur, par exemple pour convertir un code d'action numérique en libellé lisible. Le bloc output dirige les événements transformés vers Elasticsearch avec l'index de destination, le pattern de nommage et les paramètres de connexion.

4. Elasticsearch — Indexation et Gestion du Cycle de Vie

Elasticsearch est la base de données de recherche et d'indexation qui stocke tous les événements traités par le pipeline. Sa conception distribuée lui permet de traiter des milliards de documents et de répondre à des requêtes complexes en quelques millisecondes. Les données sont organisées en index, dont le nommage suit généralement une convention incluant le type de source et la date (par exemple logs-firewall-2025.11.14), permettant une gestion fine de la rétention.

La gestion du cycle de vie des index (Index Lifecycle Management — ILM) est une fonctionnalité essentielle pour maîtriser l'espace disque dans la durée. Une politique ILM définit les phases successives d'un index : la phase hot, pendant laquelle l'index est actif et les nouvelles données y sont écrites (généralement les 7 à 30 derniers jours), la phase warm, où l'index est optimisé en lecture seule et peut être déplacé sur des nœuds moins performants, la phase cold, où l'index est compressé et les requêtes sont moins fréquentes, et la phase delete, qui supprime automatiquement l'index lorsqu'il dépasse la durée de rétention définie. Cette politique est appliquée automatiquement, garantissant que l'espace disque est géré sans intervention manuelle.

Chapitre 5 : Règles de Détection et Use Cases

1. Logique de Détection dans Kibana / Elastic Security

La suite Elastic Security (module de sécurité de Kibana) propose un moteur de détection basé sur des règles exprimées en KQL (Kibana Query Language), en EQL (Event Query Language) ou en langage Lucene. Les règles KQL sont adaptées à la détection d'événements simples ou de patterns de champs, tandis que les règles EQL permettent d'exprimer des séquences d'événements temporels — par exemple, détecter un processus PowerShell lancé par Word suivi d'une connexion réseau sortante vers une IP non répertoriée dans la liste blanche, ce qui est caractéristique d'un document Word piégé exécutant un malware.

Elastic Security inclut une bibliothèque de règles de détection pré-développées, maintenues par l'équipe Elastic et mappées sur le framework MITRE ATT&CK. Ces règles couvrent des centaines de techniques d'attaque et constituent un excellent point de départ pour un SIEM en construction. Elles peuvent être importées en masse depuis le portal Elastic (Detections > Rules > Load Elastic prebuilt rules) et activées sélectivement selon les sources de logs disponibles.

2. Catalogue de Use Cases de Détection

Un use case de détection est la formalisation d'un scénario d'attaque en règle SIEM : il définit la source de logs nécessaire, la technique ATT&CK couverte, la logique de détection et l'action déclenchée. Le tableau suivant présente un catalogue de use cases fondamentaux, applicables sur Wazuh comme sur l'ELK Stack :

Use case de détection	Source de logs	Technique ATT&CK	Logique de détection
Brute force SSH	auth.log / Wazuh agent	T1110	Plus de 10 Event ID 5716 ou messages pam_unix en 5 minutes depuis la même source
Création de compte local	Windows Event Log (4720)	T1136	Event ID 4720 sur un poste non serveur, hors plage horaire administrative
Exécution PowerShell encodé	Sysmon (Event ID 1) / EDR	T1059.001	Présence du flag -EncodedCommand ou -enc dans la ligne de commande PowerShell
Connexion depuis pays inhabituel	VPN / Firewall / AD	T1078	Géolocalisation IP hors liste blanche des pays autorisés, corrélée à une authentification réussie
Modification de fichier critique	Wazuh FIM / Auditd	T1565	Modification de /etc/passwd, /etc/sudoers ou d'un binaire système surveillé

Scan de ports interne	IDS Suricata / Firewall	T1046	Source interne générant des connexions vers plus de 20 ports distincts en moins d'une minute
Service Windows installé	Windows Event Log (7045)	T1543.003	Event ID 7045 pour un service avec un nom ou chemin d'exécutable inhabituel

3. Optimisation des Règles — Réduction des Faux Positifs

Un use case nouvellement déployé génère souvent un volume important de faux positifs lors de sa mise en production. Cette situation normale ne doit pas conduire à désactiver la règle, mais à l'affiner progressivement. Plusieurs techniques permettent de réduire les faux positifs sans sacrifier la sensibilité de détection.

L'exception (whitelist) est la technique la plus directe : exclure explicitement de la règle les sources, destinations, utilisateurs ou processus dont le comportement a été validé comme légitime. Par exemple, une règle de détection de scan de ports doit exclure l'adresse IP du scanner de vulnérabilités (Nessus, Qualys) qui réalise des scans planifiés légitimes. Le seuillage (threshold) consiste à n'activer l'alerte qu'au-delà d'un nombre d'occurrences défini dans une fenêtre temporelle, évitant les alertes sur des événements isolés peu significatifs. La contextualisation ajoute des conditions supplémentaires à la règle — par exemple, une règle de création de compte utilisateur n'alerte que si l'action est réalisée hors des plages horaires d'administration définies et depuis une machine non référencée comme poste d'administration.

4. Mapping MITRE ATT&CK et Mesure de la Couverture

Le mapping des règles de détection sur la matrice MITRE ATT&CK est une bonne pratique structurante qui apporte trois bénéfices majeurs. Premièrement, il permet de visualiser graphiquement les angles morts de la couverture de détection : quelles tactiques et techniques ne sont couvertes par aucune règle active, et donc invisibles pour le SOC. Deuxièmement, il guide les priorités de développement des nouvelles règles en ciblant les techniques les plus utilisées par les groupes d'attaquants pertinents pour le secteur d'activité. Troisièmement, il fournit un langage standardisé pour les rapports de sécurité et les communications avec les équipes partenaires (CERT, prestataires forensiques, autorités).

L'outil ATT&CK Navigator, développé par MITRE et disponible en ligne ou en déploiement local, permet de créer des heat maps représentant la couverture des règles actives sur la matrice. Chaque technique est colorée selon son niveau de couverture (rouge pour non couverte, jaune pour partiellement couverte, vert pour bien couverte). Cette visualisation est particulièrement efficace pour les présentations à la direction ou au RSSI pour justifier les investissements dans le développement de nouvelles capacités de détection.

Chapitre 6 : Tableaux de Bord et Supervision

1. Architecture des Tableaux de Bord SOC

Un tableau de bord SOC efficace n'est pas une accumulation de graphiques — c'est une interface de pilotage pensée pour répondre rapidement à des questions opérationnelles précises. Sa conception doit partir des besoins des utilisateurs finaux : l'analyste N1 qui surveille en continu n'a pas les mêmes besoins que le SOC Manager qui fait un point quotidien ou que le RSSI qui produit un rapport mensuel à la direction.

Pour l'analyste N1 en surveillance active, le tableau de bord principal doit afficher en temps réel le volume d'alertes par niveau de criticité, la liste des alertes en attente de triage avec leur horodatage et leur source, les top sources d'alertes (quels agents ou systèmes génèrent le plus d'événements), et les indicateurs d'état de l'infrastructure SIEM (agents connectés, volume d'ingestion). Pour le SOC Manager, le tableau de bord hebdomadaire présente l'évolution des KPIs (MTTD, taux de faux positifs, couverture des sources), les tendances (types d'incidents en hausse, nouvelles sources détectées), et la comparaison avec les semaines précédentes. Ces deux niveaux correspondent à deux espaces Kibana distincts, avec des droits d'accès différenciés.

2. Construction d'un Tableau de Bord dans Kibana

Kibana propose un éditeur de tableaux de bord par glisser-déposer permettant d'assembler des visualisations (graphiques, tableaux, compteurs, cartes) en une interface cohérente. Les visualisations sont créées depuis l'onglet Visualize Library : un graphique en courbes représentant l'évolution du volume d'alertes dans le temps est créé en sélectionnant le type Line chart, l'index pattern correspondant aux alertes Wazuh, l'axe X sur le champ timestamp et l'axe Y en Count. Un camembert de distribution des alertes par technique ATT&CK est créé en sélectionnant Pie chart avec une agrégation Terms sur le champ rule.mitre.technique.

Pour Wazuh spécifiquement, le dashboard intègre nativement une visualisation de la matrice MITRE ATT&CK en temps réel, colorant les techniques selon le nombre d'alertes reçues dans la période sélectionnée. Il propose également des tableaux de bord pré-configurés pour les principaux modules : vue globale des alertes, vue par agent, vue FIM (modifications de fichiers), vue SCA (conformité de configuration), vue de l'intégrité des agents. Ces dashboards natifs constituent un point de départ opérationnel immédiat, personnalisable selon les besoins spécifiques de l'organisation.

3. Configuration des Alertes et Notifications

La surveillance active d'un tableau de bord par un analyste H24 est nécessaire mais insuffisante : des mécanismes d'alerte automatique doivent compléter la supervision humaine, notamment pour les alertes critiques qui requièrent une réponse immédiate, quelle que soit l'heure. Dans Wazuh, les alertes e-mail se configurent dans le fichier ossec.conf du manager (section global) en définissant le serveur SMTP, l'expéditeur et le ou les destinataires, ainsi que le niveau minimal d'alerte déclenchant l'envoi. Les alertes Slack ou

PagerDuty s'intègrent via des scripts Python personnalisés placés dans `/var/ossec/integrations/`.

Dans Kibana Elastic Security, le système d'alerting est plus sophistiqué : les règles de détection peuvent être configurées pour créer automatiquement des cas (Cases) dans le système de case management intégré, envoyer des webhooks vers des systèmes externes (TheHive, Jira, Slack) ou déclencher des actions de réponse via le connecteur Elastic. La configuration de ces intégrations se fait depuis l'interface Stack Management > Connectors, sans nécessiter d'écriture de code.

Chapitre 7 : Performance, Rétention et Maintenance

1. KPIs de Performance d'un SIEM

Un SIEM est une infrastructure critique : son indisponibilité ou ses défaillances (perte de logs, latences excessives) dégradent directement la capacité de détection du SOC. La définition et le suivi de KPIs spécifiques à l'infrastructure SIEM permettent de détecter les dérives avant qu'elles n'aient un impact opérationnel. Le tableau suivant présente les indicateurs fondamentaux :

KPI	Définition	Cible recommandée
Volume d'événements ingérés / jour	Nombre total d'événements collectés par le SIEM toutes sources confondues	Baseline à établir, surveiller les dérives > 20 %
Taux de couverture des sources	Pourcentage des actifs critiques dont les logs sont ingérés dans le SIEM	> 95 % des actifs critiques
Latence d'ingestion	Délai entre génération d'un événement et son indexation dans le SIEM	< 60 secondes
Taux de faux positifs	Proportion d'alertes ne correspondant pas à un incident réel	< 10 % des alertes générées
Couverture ATT&CK	Pourcentage de techniques MITRE ATT&CK couvertes par au moins une règle active	> 50 % (progressif)
Disponibilité du SIEM	Uptime de l'infrastructure SIEM (indexer, manager, dashboard)	> 99,5 %
Durée de rétention effective	Période réelle sur laquelle les événements sont interrogeables	> 90 jours (hot), > 12 mois (archive)

2. Gestion de la Rétention et du Stockage

La gestion du stockage est l'une des principales préoccupations opérationnelles d'une infrastructure SIEM en production. Le volume de données ingérées croît avec le nombre de sources et l'évolution du SI ; sans politique de rétention active, l'espace disque sature inévitablement. Dans l'ELK Stack, la politique ILM automatise la gestion du cycle de vie des index selon les paramètres définis (durée de chaque phase, taille maximale par index, action de suppression). Dans Wazuh, la rétention des alertes dans l'indexer OpenSearch est gérée par des politiques ISM (Index State Management), l'équivalent OpenSearch des politiques ILM Elastic.

Pour les données devant être conservées au-delà de la durée de rétention en ligne (par exemple, 12 mois d'archives pour NIS2 mais seulement 90 jours en hot storage pour des raisons de coût), des solutions d'archivage froid sont nécessaires. Les index Elasticsearch/OpenSearch peuvent être snapshot vers un stockage objet compatible S3 (AWS S3, MinIO en local, OVH Object Storage) et restaurés à la demande en cas de besoin d'investigation. Cette architecture à deux niveaux (hot online + cold archive) permet d'optimiser les coûts tout en respectant les obligations réglementaires de rétention.

3. Maintenance Opérationnelle d'un SIEM

Un SIEM nécessite une maintenance régulière pour conserver son efficacité dans le temps. Plusieurs tâches récurrentes doivent être intégrées dans les processus opérationnels de l'équipe. La mise à jour des composants est la première priorité : Wazuh publie des mises à jour régulières qui corrigent des vulnérabilités, améliorent les performances et enrichissent la base de règles. Des vulnérabilités dans le SIEM lui-même constituent un risque de sécurité majeur (un attaquant accédant au SIEM peut lire l'ensemble des logs et potentiellement effacer les traces de son intrusion).

La vérification de la couverture des sources est une tâche mensuelle indispensable : comparer la liste des actifs inventoriés dans la CMDB avec la liste des agents actifs dans Wazuh pour identifier les systèmes non supervisés. La revue des règles désactivées ou silencieuses (règles actives n'ayant généré aucune alerte depuis plusieurs mois) permet d'identifier les règles potentiellement inadaptées au contexte ou dont la source de logs n'est plus collectée. Enfin, le test périodique des alertes (envoi volontaire d'un événement connu pour vérifier que la règle se déclenche correctement) valide la chaîne de détection de bout en bout.

Chapitre 8 : Cas Pratique — Déploiement d'un SIEM pour une ETI

1. Présentation du Contexte

MediConsult SA est une entreprise de conseil en santé de 180 salariés, traitant des données de santé à caractère personnel. Suite à un audit de conformité HDS (Hébergeur de Données de Santé) et à l'entrée en vigueur de NIS2 pour son secteur, la DSI doit déployer un SIEM avec une rétention de 12 mois minimum, une couverture de 100 % des serveurs traitant des données de santé, et des alertes opérationnelles en moins de 5 minutes sur les événements critiques. Le budget infrastructure est limité, orientant naturellement le choix vers Wazuh open source, déployé sur un serveur dédié dans le datacenter de l'entreprise.

L'infrastructure à superviser comprend : 12 serveurs Linux hébergeant les applications métier, 8 serveurs Windows (Active Directory, serveur de fichiers, Exchange, RDS), 150 postes de travail Windows 10/11, un pare-feu Fortinet FortiGate, et deux switches Cisco Catalyst gérant la segmentation réseau. La DSI dispose d'une équipe de 3 personnes dont un responsable sécurité à 50 % de son temps.

2. Phase 1 — Installation et Configuration de Base

Wazuh est installé sur un serveur Ubuntu 22.04 LTS dédié, dimensionné à 16 Go de RAM, 8 cœurs et 500 Go SSD. L'installation tout-en-un via le script officiel est réalisée en 20 minutes. La première configuration concerne la politique de rétention : dans l'interface d'administration OpenSearch, une politique ISM est créée pour conserver les index en phase hot (pleinement interrogeables) pendant 90 jours, puis en phase warm (compressés, lecture seule) pendant 9 mois supplémentaires, soit une rétention totale de 12 mois conforme aux exigences NIS2.

Les alertes e-mail sont configurées pour les niveaux 10 et supérieurs (incidents élevés et critiques), avec envoi vers une liste de diffusion sécurité incluant le responsable sécurité et le DSI. Un webhook Slack est configuré pour les alertes de niveau 12 et supérieures, garantissant une notification immédiate sur le smartphone du responsable sécurité en permanence, même hors des horaires de bureau.

3. Phase 2 — Déploiement des Agents et Sources

Le déploiement des agents sur les 12 serveurs Linux est automatisé via un playbook Ansible qui installe le package wazuh-agent, configure le fichier `/var/ossec/etc/ossec.conf` avec l'adresse du manager et active le FIM sur les répertoires `/etc/`, `/usr/bin/`, `/usr/sbin/` et les répertoires applicatifs. Sur les serveurs Windows, un script PowerShell déployé par GPO installe l'agent MSI et configure son enregistrement auprès du manager. Deux semaines après le déploiement, 100 % des serveurs critiques sont couverts, ainsi que 43 % des postes de travail (déploiement progressif).

Pour le FortiGate, la configuration Syslog dans l'interface web du pare-feu (Log & Report > Log Settings) pointe vers l'IP du serveur Wazuh sur le port 514 UDP, avec le niveau de log

Information et la facility local0. Côté Wazuh, un décodeur personnalisé pour le format FortiGate est ajouté dans `/var/ossec/etc/decoders/fortinet_decoder.xml`, extrayant les champs action, srcip, dstip, service et policyid des logs CEF émis par le pare-feu. Après validation des décodeurs par la commande `wazuh-logtest`, les logs FortiGate commencent à alimenter le SIEM et les règles de détection réseau entrent en vigueur.

4. Phase 3 — Règles Personnalisées et Bilan

Cinq règles personnalisées sont développées en priorité, adaptées au contexte MediConsult. La première détecte l'accès aux répertoires contenant des données de santé depuis un compte non autorisé (via FIM et les logs d'audit Linux). La deuxième alerte sur toute connexion RDP vers les serveurs depuis une IP hors du VLAN d'administration. La troisième détecte les modifications de la configuration du pare-feu FortiGate (Event ID spécifique dans les logs Syslog FortiGate). La quatrième alerte sur toute désactivation du service Wazuh agent sur un endpoint supervisé (ce qui pourrait indiquer une tentative de désactivation des défenses par un attaquant). La cinquième corrèle les échecs d'authentification SSH suivis d'une authentification réussie pour détecter les brute force ayant abouti.

Après six semaines d'exploitation, le bilan est positif : 97 % des serveurs critiques sont supervisés (un serveur legacy pose des problèmes de compatibilité d'agent, en cours de résolution), le volume d'alertes quotidiennes est de 23 alertes en moyenne (dont 18 % de faux positifs, principalement liés aux scripts de sauvegarde), trois incidents réels ont été détectés et traités (deux tentatives de brute force SSH bloquées, une modification non autorisée d'un fichier de configuration applicative), et la couverture ATT&CK atteint 38 % des techniques, avec un plan pour atteindre 55 % dans les 6 prochains mois via le développement de 12 règles supplémentaires prioritaires.

Synthèse Générale du Module

Ce cours vous a conduit depuis le choix d'un SIEM open source jusqu'à son exploitation opérationnelle dans un contexte d'entreprise réel, en passant par l'architecture, le déploiement, la configuration des règles de détection et la construction des tableaux de bord de supervision. La progression adoptée reflète la réalité du terrain : un SIEM se construit progressivement, par couches successives, en commençant par l'infrastructure et la collecte avant de monter en sophistication sur la détection et l'automatisation.

Trois grandes leçons synthétisent l'ensemble du cours. La première est que la qualité de la collecte conditionne la qualité de la détection. Un SIEM dont la couverture de sources est incomplète est un SIEM aveugle sur les portions non supervisées du SI. Avant d'investir du temps dans le développement de règles sophistiquées, il faut s'assurer que l'ensemble des actifs critiques envoie leurs logs et que ces logs sont correctement parsés et normalisés. Une règle de détection brillante appliquée sur des logs mal structurés ne détecte rien.

La deuxième leçon est que le SIEM est un outil vivant, pas un projet à terme. La menace évolue, le SI évolue, les règles doivent évoluer avec eux. Les groupes d'attaquants changent leurs techniques, de nouvelles CVE sont publiées, de nouveaux services cloud sont adoptés

par les équipes métier sans validation de la DSI. Le SIEM qui n'est pas maintenu activement perd progressivement sa pertinence : ses règles deviennent inadaptées, ses couvertures sources se dégradent, ses alertes sont ignorées faute de pertinence. La maintenance opérationnelle d'un SIEM est un engagement permanent, qui justifie de lui dédier une fraction du temps d'un analyste.

La troisième leçon est que la mesure est indispensable à l'amélioration. Sans KPIs définis et suivis, il est impossible de savoir si le SIEM s'améliore ou se dégrade dans le temps, ni de justifier les investissements nécessaires à son évolution auprès de la direction. Le taux de couverture ATT&CK, le taux de faux positifs, la latence d'ingestion et la disponibilité de l'infrastructure sont les quatre indicateurs minimaux à mesurer dès le premier jour d'exploitation pour piloter efficacement la montée en maturité de la capacité de détection.

Glossaire

Terme	Définition
Agent SIEM	Logiciel léger déployé sur chaque endpoint supervisé, chargé de collecter les événements locaux et de les transmettre au manager ou au serveur central.
Auditbeat	Agent Elastic spécialisé dans la collecte des événements d'audit système (syscalls Linux, modules de noyau, fichiers modifiés) pour transmission vers l'ELK Stack.
Corrélation	Opération consistant à mettre en relation plusieurs événements de sources différentes pour détecter un comportement malveillant composite non détectable par une alerte simple.
Decoder Wazuh	Composant du manager Wazuh chargé d'extraire les champs structurés (IP, utilisateur, action) d'un message de log brut via des expressions régulières.
ECS	Elastic Common Schema — schéma de normalisation des champs de logs développé par Elastic pour garantir l'interopérabilité entre les sources et les outils de l'écosystème.
EQL	Event Query Language — langage de requête Elastic permettant d'exprimer des séquences d'événements temporels pour la détection de comportements en plusieurs étapes.
FIM	File Integrity Monitoring — fonctionnalité du SIEM ou de l'agent surveillant les modifications de fichiers et répertoires critiques (binaires système, fichiers de configuration).
Grok	Langage de pattern matching utilisé dans Logstash et Graylog pour parser des logs non structurés et en extraire des champs nommés exploitables.
ILM	Index Lifecycle Management — politique Elasticsearch/OpenSearch définissant automatiquement les phases de vie d'un index (hot, warm, cold, delete) en fonction de l'âge ou du volume.
Index	Structure de stockage et d'indexation dans Elasticsearch / OpenSearch regroupant des documents JSON partageant un même schéma, requêteable via l'API REST.
Normalisation	Transformation des logs de formats hétérogènes (Syslog, CEF, JSON, EVTX) en un format unifié facilitant la corrélation et la recherche cross-sources.
OSSEC	Open Source HIDS Security — système de détection d'intrusion basé sur les hôtes dont Wazuh est le fork le plus actif et le plus riche en fonctionnalités.
Pipeline Logstash	Séquence de traitement composée d'un bloc input (source), d'un ou plusieurs blocs filter (transformation) et d'un bloc output (destination) définissant le flux de traitement des événements.
SCA	Security Configuration Assessment — module Wazuh vérifiant la conformité de la configuration des systèmes supervisés par rapport à des benchmarks (CIS, PCI-DSS, NIST).
SIEM	Security Information and Event Management — plateforme centralisant la collecte, la normalisation, la corrélation et l'alerte des événements de sécurité d'un système d'information.

Wazuh	Plateforme SIEM open source dérivée d'OSSEC, intégrant la détection d'intrusion sur les hôtes (HIDS), le monitoring de l'intégrité des fichiers (FIM), l'évaluation de la configuration (SCA) et la réponse active.
-------	---